



Securing critical infrastructures with a cybersecurity digital twin

Massimiliano Masi¹ · Giovanni Paolo Sellitto² · Helder Aranha³ · Tanja Pavleska⁴

Received: 1 March 2022 / Revised: 18 November 2022 / Accepted: 5 December 2022 / Published online: 2 January 2023
© The Author(s), under exclusive licence to Springer-Verlag GmbH Germany, part of Springer Nature 2022

Abstract

With the diffusion of integrated design environments and tools for visual threat modeling for critical infrastructures, the concept of Digital Twin (DT) is gaining momentum in the field of cybersecurity. Its main use is for enabling attack simulations and evaluation of countermeasures, without causing outage of the physical system. However, the use of a DT is considered foremost as a facilitator of system operation rather than an integral part of its architecture design. In this work, we introduce a specific architecture view in the system representation, called Cybersecurity View. From it, we derive a cybersecurity Digital Twin as part of the security-by-design practice for Industrial Automation and Control Systems used in Critical Infrastructures. Not only this digital twin serves the purpose of simulating cyber-attacks and devising countermeasures, but its design and function are also directly tied to the architecture model of the system for which the cybersecurity requirements are posed. Moreover, this holds regardless of whether the model is generated as part of the development cycle or through an empirical observation of the system as-is. With this, we enable the identification of adequate cybersecurity measures for the system, while improving the overall system design. To demonstrate the practical usefulness of the proposed methodology, its application is illustrated through two real-world use cases: the Cooperative Intelligent Transport System (C-ITS) and the Road tunnel scenario.

Keywords Enterprise architecture · Reference architecture · Cybersecurity view · Digital twin · Threat modeling · Critical infrastructure · Transportation

1 Introduction

In the past, physical models have been widely used in engineering and architecture to help the design and facilitate physical testing of buildings, plants, machines and systems. Well-known examples of this practice are architecture models of buildings, the wind-tunnel models used in aerodynamic testing, hydrodynamic and stability testing of vessel hull models in water tanks, etc. The advance of digitization allowed extending this approach to the digital world, where digital models can be used to forecast the behavior of systems and artifacts with increasing degrees of fidelity. These models bring in several benefits, since they allow to overcome the limitations of physical models in terms of scale, cost, flexibility and re-usability, especially in the design phase. Other benefits are the possibility of exploring changes to systems in production, as well as simulating conditions and stresses that cannot be applied to the real system without detrimental consequences. Last but not least, they enable seamless modeling of digital and physical components of cyberphysical systems. One such model is the Digital Twin (DT), a digital representation of the real system, containing sufficient infor-

Communicated by E. Serral Asensio, J. Stirna, J. Ralyté, and J. Grabis.

Massimiliano Masi, Giovanni Paolo Sellitto, Helder Aranha and Tanja Pavleska have contributed equally to this work.

✉ Massimiliano Masi
mmasi@autostrade.it
Giovanni Paolo Sellitto
gogiampaolo@gmail.com
Helder Aranha
hmspider@gmail.com
Tanja Pavleska
atanja@e5.ijs.si

¹ IT and Digital Transformation, Autostrade Per L'Italia SpA, Via Bergamini, 00159 Rome, Italy

² Rome, Italy

³ Lisbon, Portugal

⁴ Laboratory for Open Systems and Networks, Jozef Stefan Institute, Jamova cesta 39, 1000 Ljubljana, Slovenia

mation to control specific operational parameters or aspects of its (cyber)physical counterpart.

In this paper, we explore the possibility to use the Digital Twin to improve the Business Continuity plans and the overall safety of critical infrastructures, simulating and assessing the cybersecurity aspect of large Industrial Automation and Control Systems (IACS).¹ We adopt an Enterprise Architecture approach to cybersecurity, encompassing threat-based simulation, threat assessment and countermeasure evaluation. It can be applied to the whole system life-cycle: from design/construction to production/exploration and phase-out. Critical infrastructures are typically complex cyberphysical systems formed by many interdependent subsystems, often supported by large Industrial and Automation Control Systems. IACSSs, in turn, are complex systems on their own. According to the European Joint Research Centre, the term IACS refers to all the components (PLCs, SCADA, HMI, etc.) that are integrated into critical infrastructures and industrial production establishments,² which are also the parts of the system which expose an attack surface to the functioning of the critical infrastructures. The simulation and assessment of Business Continuity Plans of critical infrastructures (including respective IACS), as laid out in international best practices (such as ISO 22301) and also required by national regulations, are usually restricted to design/construction phases, since halting a critical system to perform business continuity testing is not an option.

Based on the above, we have identified and addressed two main challenges. First, IACSSs are often custom-built, and their legacy system architecture models are not developed through a standardized or even disciplined architectural approach. We address this challenge by positing the adoption of a reference architecture framework suitable for industrial automation systems, so as to describe the cybersecurity aspects of real-life IACS via a process akin to reverse engineering. Then, by executing security controls adequate to critical infrastructures as prescribed in the NIST Cybersecurity Framework [1], we identify in a structured manner both the security countermeasures and the security control processes that persist over an existing IACS. The outcome of security controls execution is then mapped onto the chosen reference architecture framework. The second challenge can be seen as an analogue to ‘modeling impedance’: namely, typical EA models used in industrial automation and the models used in visual threat modeling differ both with respect to their concerns and their modeling practices, which can result in an EA model that is not suitable for threat modeling, and vice versa. Visual threat modeling tools offer many

benefits to the security architect with respect to work efficiency, exploring cost-effective countermeasures and quickly assessing risks by simulation. We have thus overcome this impedance by leveraging the architectural concepts of Viewpoint and View to build a bridge view model. The modeling constraint is a set of rules to build a cybersecurity view of IACS based on a given reference architecture framework, such that the resulting view model is amenable to translation into a visual threat modeling language. With this, the cybersecurity view is devised simultaneously with the overall architecture, whereas the architecture framework is decoupled from the visual threat modeling language itself.

In addressing the above challenges, this paper extends on our previous work, where a methodology was designed to derive the digital twin from a solution architecture in order to perform cybersecurity simulations and visual threat modeling [2,3]. More specifically, through the current work, we extend the methodology to enable its application to critical infrastructures, namely to IACSSs. Updating it in a way that decouples the approach from the architecture development phase and its deliverables, it can also be applied to legacy systems already in operation which lack architectural documentation.

To illustrate the practical relevance of the proposed methodology, we apply it to two real-world IACS use cases: one in the context of Cooperative Intelligent Transport Systems (C-ITS) and the second in a Road Tunnel scenario. With these examples, we address both the case where an architecture blueprint is available and the one of a legacy system, like the road tunnel. The outcome is a framework for the design of cybersecurity digital twins for critical infrastructures enabling cybersecurity evaluation and identification of countermeasures, without any outage of the operational system.

The remainder of this paper is structured as follows: Sect. 2 positions our work among the research on Digital Twins and Cybersecurity. Section 3 presents the preliminary concepts needed to frame and understand the presented work. Section 4 describes the methodology to define a cybersecurity viewpoint, to derive a cybersecurity view and to distill a Digital Twin. Section 5 presents the application of the methodology to the C-ITS and Road Tunnel use cases. Finally, in Sect. 6 we present a concluding discussion based on the current work and touch upon future work as well.

2 Related works

In this section we present works that complement or are similar to our work. The section is divided in three parts. We first report works related to the uses of a digital twin in general, but also such that are specific for cybersecurity. Then, we proceed with works related to the use of threat models, and

¹ As defined in ISO 62443. Equivalent to *Industrial Control Systems*, a term still in use.

² See, <https://erncip-project.jrc.ec.europa.eu/networks/tgs/european-iacs>.

how they are derived from the system architecture. Finally, we overview the use of Enterprise Architectures and Frameworks in the context of Critical Infrastructures, which further motivates our approach.

On the use of Digital Twin. The concept of Digital Twin has been the topic of many publications, coming both from industry and from academia. A survey is presented in [4], and a review including gray literature is performed by [5]. In the latter work, authors found that the reported use of digital twins in incident protection is related to intrusion and anomaly detection, monitoring, and virtual commissioning, without considering cybersecurity, which is our main concern. In particular, digital twins are considered as communicating with their physical counterpart, implying that the effect of a change on the Digital Twin results in an immediate exchange with the physical world: this is not always possible nor safe in the case of IACS. In our case, the Digital Twin is not communicating nor interacting with the real counterpart; it remains an architectural view exploited in the design process and during operations. A detailed discussion is in Sect. 3.2. In [6], a further taxonomy of digital twins is made: they are divided in Digital Shadows, Models, and Twins, depending on how the replica influences the physical world. According to this definition, our work can be considered as a digital shadow; however, we borrow a definition from literature which does not consider this taxonomy. In [7], the work we consider closest to ours, authors introduce the integration of a Digital Twin for Cybersecurity with an event log collector (a SIEM³ system), to help SOC⁴ analysts in finding correlations in case of attacks. In turn, our methodology addresses every security-relevant architectural asset and maps them into items of a cybersecurity-specific modeling language named Meta-Attack-Language (MAL).

The use of digital twins for security is not novel. In [8], authors define one method to design a Digital Twin. Our work acknowledges this method and further proposes a framework-agnostic methodology integrating a procedure to devise a specific Architecture View. In [9], the authors lay down some concepts for the use of DT for security purposes, namely to reduce the attack surface and to perform intrusion detection. A framework that, starting from system specifications, creates a model to be used for simulations is presented in [10], where the authors concentrate on IACS and build a DT by leveraging the data exchange format. Similar to these works, our approach is focused on the security aspects, but it is parametric to the EA (see Sect. 3) and can thus be applied to a variety of systems, regardless of the Reference Architecture of choice. In addition to encompassing the physical aspects of the system, this approach also takes into account the organization's business objectives. As a result, security

is addressed as a *cross-cutting concern*, spanning from the cyberphysical components to data communication, data syntax, semantics, functionalities, and business models.

On the use of models. Using models for security evaluations is part of a research area named threat modeling. In [11], authors evaluate the extent to which countermeasures can improve the security posture of SCADA-based systems supporting a power grid. Similar to our work, the Energy Shield project derives a model for security simulations using System Theory Process Analysis (STPA) [12]. We further generalize this approach by formalizing the Enterprise Architecture modeling and its application, enabling simulations and testing for a wide set of contexts and applications. OWASP⁵ defines threat modeling as a way to identify and understand threats, evaluate mitigation practices to protect a valuable asset and define best practices on how to protect it. The digital representation of the system proposed here follows these principles by performing threat modeling over a comprehensive digital representation of the entire system. Furthermore, it takes into account the assets to protect, data flows and messages, as well as the system functionalities and the organization's business objectives. Additional modeling aspects to those presented above have been outlined in [13], where a DT was built to demonstrate privacy enhancement mechanisms in the automotive industry, starting off by identifying the stakeholders. As the approach taken in this work is systematic, the definition of an architecture model for new systems is part of the overall design. For existing systems, the architecture models are obtained by performing the equivalent to reverse engineering.

On the use of Enterprise Architecture in the context of IACS and Critical Infrastructures. Enterprise Architectures facilitate stakeholders in increasing their domain knowledge [14] and enable the business management to take informed strategic decisions [15]. The latter point is of particular interest for critical infrastructures to facilitate decision-makers in their decisions and discussions when planning the cybersecurity budget. According to the EU Network and Information Systems (NIS) directive [16], operators of essential services are a subset of critical infrastructures. Among the essential services we find *cooperative intelligent transport systems (C-ITS)*, a set of services implemented by motorways, smart cities, and vehicle manufacturers, that cooperate together for a safer and greener transportation. These systems are usually built and operated in a systematic manner, based on the design of an Enterprise Architecture (EA) [17,18], precisely in the manner discussed in this work. In particular, in C-ITS, a layered architecture is presented [18], but other critical infrastructures take a similar approach. The differences mainly stem from the particular architecture frameworks used: the

³ Security Information Event Management.

⁴ Security Operation Centre.

⁵ See https://owasp.org/www-community/Application_Threat_Modeling.

energy sector leverages the Smart Grid Architecture Model, SGAM [19], whereas the healthcare sector employs (and is also regulated by) the Integrating the Healthcare Enterprise (IHE) architecture framework [20,21].

It is worth noting that IACS of Road Tunnels are not yet well regulated in terms of cybersecurity, nor there is an active community in the area. Apart from [22], which is the most relevant publication in the field, not much related works are available. This fact deserves a special consideration, since sector-specific risks are largely underestimated and the risk analysis is often based on generic risk tables (e.g., according to ISO 27005).

Cybersecurity is a concern in all architecture frameworks. RAMI 4.0 [23] utilizes an approach which we consider in Sect. 4.2, while The Open Group Architectural Framework (TOGAF) considers it by providing guidance on Cybersecurity and the ADM [24]. In the Smart Grid, SGAM, being a layered architecture, considers security by design aspects [25] using the sentence “Cybersecurity as a cross-cutting concern” (borrowed from GWAC) [26]. IIRA [27] and IoT RA [28], as introduced in Sect. 3.1.1, tackle security as a property of a View and consider it as a concern spanning throughout all layers. In particular, IIRA has an accompanying document, its Security Framework, further specifying how security is applied layer by layer [29]. As it will be described further in the paper, we do not prescribe a particular architecture framework. We let the architect “tag” cybersecurity properties in the architecture layers, and subsequently, we build the DT by selecting all tagged items and mapping them into MAL. This is not hindering the way how Security is handled by the various frameworks, by, e.g., evaluating risks, or considering properties to focus on. Documents such as [29] further prescribe simulations for the DT that we systematically build, by, e.g., putting a particular focus on properties such as trustworthiness, reliability, and availability.

3 Theoretical background

This section introduces the main concepts used throughout the paper. First, we define the concepts used in the field of Enterprise Architecture, explaining why and how they are relevant for the design of a digital twin.

3.1 Enterprise architecture, viewpoints and views

Enterprise Architecture (EA) is the organizing logic for business processes and IT infrastructure, reflecting the integration and standardization requirements of the firms’ operating model [30]. It is a description, and a representation of a system in terms of frameworks, models, and blueprints, which are diagrams, schema or other visualization of the architecture at the conceptual, logical and physical level. An

architectural approach to system analysis and design defines a rigorous and repeatable methodology to define which are the system components and the rules for their interaction, in order to understand how the system works and what are the requirements for obtaining a desirable behavior. Some models produced by EA are prescriptive, in the sense that the design activities define how the system shall be; other models are descriptive, in the sense that they describe how the system is. Usually, the activities of system design rely on a *Reference Architecture (RA)*, which is a conceptual model providing the template to represent an *Enterprise Architecture* in a particular domain.

Central to our methodology are the architectural constructs of *viewpoint* and *view*, which we borrow from [31]. As expressed concisely in TOGAF [24], “a view is defined as a part of an Architecture Description that addresses a set of related concerns and is tailored for specific stakeholders. A view is specified by means of a viewpoint, which prescribes the concepts, models, analysis techniques, and visualizations that are provided by the view.” In our case, the viewpoint is that of Cybersecurity, framing the technical and business concerns of stakeholders such as cybersecurity practitioners and decision makers with critical infrastructures. While the latter define *what* to protect, the former know *how* to protect, working together to assess acceptable—read cost-effective—risk exposure to threats. An *Architecture framework* establishes a common practice for using architecture descriptions (even in form of EAs) within a particular domain of application or stakeholder community [31]. Our methodology relies on the use of frameworks since we target the community of cybersecurity practitioners in Critical Infrastructures. However, as it will be shown in Sect. 3.1.1, we do not mandate a specific one.

3.1.1 Reference architectures and architecture frameworks

A reference architecture provides a generic template for solution architectures, usually targeted at dealing with a particular domain. Addressing cybersecurity straight in the Reference Architectures is a form of *Security By Design*, since the concern is dealt with right from the initial definition of the technical solution of the system. Therefore, cybersecurity should be a mandatory concern for Reference Architectures, to allow the architects to develop a *Solution Architecture* from a template which can be considered secure. For this reason, in our methodology we consider both the concepts of Solution Architecture and Reference Architecture.

A number of Reference Architectures and Architectural Frameworks have emerged for the Internet of Things, which nowadays is the main paradigm for IACSs. The Reference Architecture for Industry 4.0 (RAMI 4.0) [23] defines viewpoints that are typical of industrial automation, while the Internet of Things Reference Architecture (IoT RA)

Table 1 Comparison between layers in EAs

IoT RA	IIRA	RAMI 4.0
	Business	Business
Usage	Usage	
Functional	Functional	Functional
Information		Information
Communication		Communication
System	Implementation	Integration
		Asset

[28] presents an integrated architectural model for IoT. The Industrial Internet Reference Architecture (IIRA) [27] is specifically devised for industrial control systems. These models/frameworks share the concept of *Architecture Layers* [32]. Layers enable architects to express different stakeholder concerns regarding the system to be designed, usually from a technical level up to a business level. The similarities between these reference architectures in terms of viewpoints, views, and architectural layers have been pointed out by other works [28,33], as shown in Table 1.

We do not prescribe any particular framework to be used, as our methodology is parametric and supports any of the above RAs. In our work, we exploit the concept of layers to realize the cross-cutting nature of cybersecurity: all layers have to be secured (*defense-in-depth*). As will be shown in Sect. 4, we will derive the Digital Twin from a specific Cybersecurity View, which, in turn, is derived by projecting the assets to be secured over whatever architecture layers to implement defense-in-depth. Notably, we will use RAMI 4.0 framework throughout this paper to illustrate the building of the cybersecurity view. The reason behind this choice is that RAMI is the framework used in Industry 4.0 and the Industrial Internet of Things, which are suited for the use cases that will be presented in Sect. 5.

3.1.2 Reference model for industry 4.0: RAMI 4.0

RAMI 4.0 represents a consolidated architectural framework for Industry 4.0 [34].

The conceptual space, depicted in Fig. 1, is structured along three axes. The first axis defines six architectural layers: the *business layer* addresses the economic and regulatory aspects; the *functional layer* describes the functionality implemented by the various architectural assets and their run-time environment; the *information layer* describes data that feed the system information flows and is used to support the semantic interoperability aspects; the *communication layer*, in turn, describes the access to information and the functions of a connected asset (e.g., REST, SOAP, DSRG, 5G); the *integration layer* represents the transition from physical

to information world (e.g., man–machine interfaces); and, finally, the *asset layer* covers the assets that exist in the physical world (sensors, actuators, and SCADA).

The second axis is called *Life cycle & Value stream* and is distinguished by two aspects, instance and type: the type represents the conceptual space, while the instance represents the tangible space—a physical or a digital object in the system memory.

The third axis, the *Hierarchy*, consists of: *Product*, describing the unit produced by a system/machine; *Field Devices* and *Control Devices*, i.e., physical units coordinating other devices; *Stations*—systems grouped together into a *Work Center*; *Enterprise*, which is the organization, and the *Connected World*, which is the interface with the external environment.

The application of RAMI 4.0 in our proposal is exemplified by the use cases presented in Sect. 5, where the concrete assets obtained from the system description are mapped to their corresponding RAMI 4.0 layer.

The concern of Cybersecurity is not only tackled by RAMI 4.0, but it is considered as an aspect that should always be included in the description of each of the three axis [23]. In fact, RAMI 4.0 identifies a basic Security View, where security properties such as Availability, Integrity, and Confidentiality are tagged. In our work, we inherit this viewpoint to construct the Cybersecurity View in Sect. 4.2.

3.2 Digital twin

There are several definitions for a *digital twin*. In our work, we consider the following definition: a Digital Twin is a virtual description of a physical product that is accurate to both micro- and macro-level [35]. Digital twins are expected to exhibit *fidelity*, i.e., a high number of parameters transferred between the physical and virtual entity, high accuracy and a satisfying level of abstraction [4]. In [9], digital twins are used to perform simulation of the security aspects of cyber and physical systems to enable security by design, whereas in [36], they are defined as “an evolving digital profile of the past and current behaviour of a physical object or process.” Following the reasoning in [9], the **cybersecurity digital twin** is defined as a “virtual replica of the system that accompanies its physical counterpart during its lifecycle, consumes real-time data if required, and has the sufficient fidelity to allow the implementation, testing, and simulation of desired security measures and business continuity plans.”

However, these representations alone cannot show if the system is secure or if a recovery plan is effective. Therefore, our methodology supports cost-effectiveness analysis to find the balance between security and usability, safety, functionality and pay-off. By creating a specific cybersecurity digital twin, the verification of the desired security properties and the cost-effectiveness analyses, *ex-ante* or during system

the Solution Architecture of the system, or its template, the Reference Architecture. Firms embracing EAs provide architectural templates in the form of Reference Architectures that must be considered secure, even when engaging external suppliers. For existing systems, on the other hand, a descriptive architectural model is produced by mapping the existing system into either a Solution or Reference Architecture, mapping the real system onto a target EA conceptual space.

Identifying cost-effective countermeasures is achieved through the following steps: mapping the cybersecurity view into a model targeted at supporting cyber-attack simulations (comprising of both the assets to be protected and the devised countermeasures), running simulations, and adjusting the model until an acceptable threat risk level is achieved. The results can then be transferred back from the digital twin to the real system.

4.1 Specifying the cybersecurity viewpoint

Considering the above, we will encapsulate our methodology as a Cybersecurity Viewpoint according to [31, Section 5] definition:

- *Overview* Enabling the assessment of Business Continuity Plans and the security posture of Industrial Automation Control Systems (IACSs) supporting new and existing critical infrastructures. Such assessment is assumed to be performed by security threat simulation. Modeling guidelines include the creation of a cybersecurity view, which contains the assets to protect. This view is translated into a Digital Twin that supports iterative simulation and evolution cycles.
- *Concerns* Decrease the cyber-threat risk to acceptable levels. Determine cost-effective countermeasures for desired security posture. Comply with international best practices and national regulations regarding protection and business continuity of critical infrastructures. Adopting security by design principles for new IACS. Continuously and safely reassess threat level for existing IACS under operation (non-stop).
- *Anti-concerns* ROI analysis, orthogonal to cybersecurity. Describing security countermeasures techniques. Qualitative risk analysis.
- *Typical stakeholders* business decision makers and cybersecurity experts (security architects and testers) in organizations owning or operating critical infrastructures.
- *Model kind* while no model family is specifically prescribed for the cybersecurity view governed by this viewpoint, the general process to assess cybersecurity of a IACS shall include:
 1. Choosing a Reference Architecture framework suitable to describe IACS's and generate a cybersecurity

view of the system-of-interest according to Sect. 4.2. This includes tagging all assets deemed as relevant to cybersecurity ("assets to protect") and *project* them over the architectural layers of the chosen framework.

2. Translating the cybersecurity view into a Digital Twin ensuring fidelity according to Sect. 4.3.
3. Identifying attack scenarios, perform simulations and tweak security countermeasures until an acceptable risk exposure is achieved according to Sect. 4.4.

The end-to-end process is depicted in Fig. 2, instantiated with the RAMI 4.0 framework (see Sects. 3.1.1 and 3.1.2).

4.2 Phase 1: generating a cybersecurity view

The first step in the generation of the cybersecurity view is the choice of an Architecture Framework. In this paper, the design is carried out using RAMI 4.0 (see Sect. 3.1.1). However, the methodology and the final result do not depend on the chosen Architecture Framework, as long as it is a framework that adequately supports system analysis and design in the context of interest. By using the mapping mechanism from one Architecture Framework to another, shown in Table 1, equivalent architecture frameworks can be mapped into each other.

In the case of a legacy system already in operation, a mapping mechanism is required to move from the real system to the EA conceptual space, the Solution Architecture or the Reference Architecture. For this purpose, we rely on the NIST Cybersecurity framework (NIST CSF) [1], as it is technology-agnostic and used in a broad range of critical sectors. Moreover, it provides specific guidance on tailoring traditional IT security controls to accommodate IACS performance, reliability and safety requirements. Executing the prescribed security controls allows us to identify the underlying assets to protect. A step-by-step demonstration on how this mapping is performed can be found in [38]. However, in the case of IACSs, it is also recommended to define and map data flows in order to segment and segregate the network traffic, as well as to identify firewall rules.⁷ The output of this phase is a catalog of assets categorized through the chosen RA, which feeds into the procedure for devising the countermeasures.

In all these cases, the physical and digital assets to protect are categorized following the concepts prescribed by the Architectural Framework. When RAMI 4.0 is used as the reference conceptual space, the resulting taxonomy has the form of a catalog of the assets to be protected categorized by the RAMI 4.0 architectural layers. It is worth noting that

⁷ See, e.g., NIST cybersecurity framework for the protection of critical infrastructure [1].

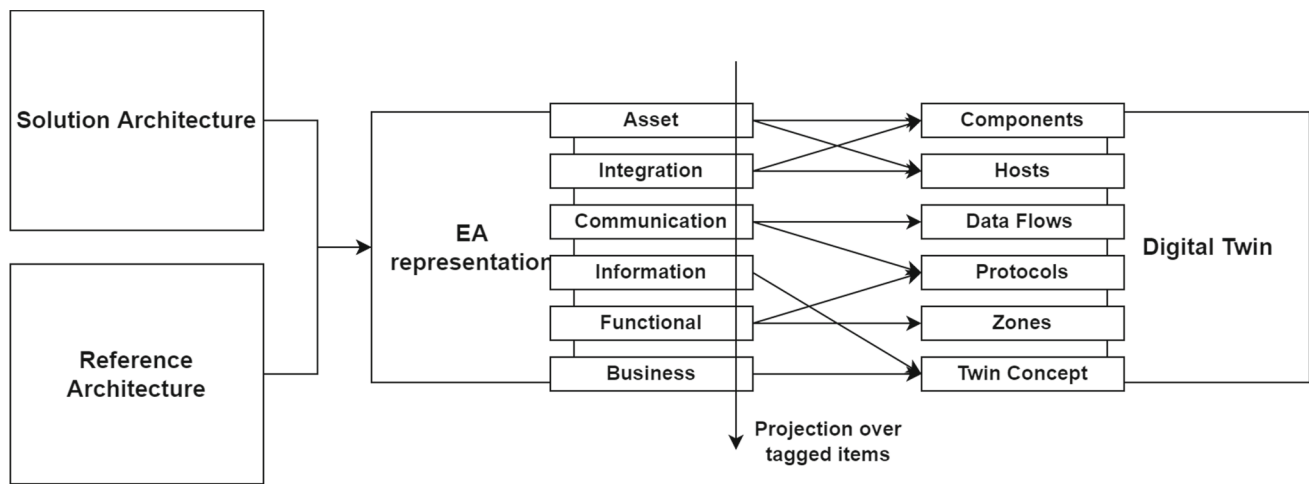
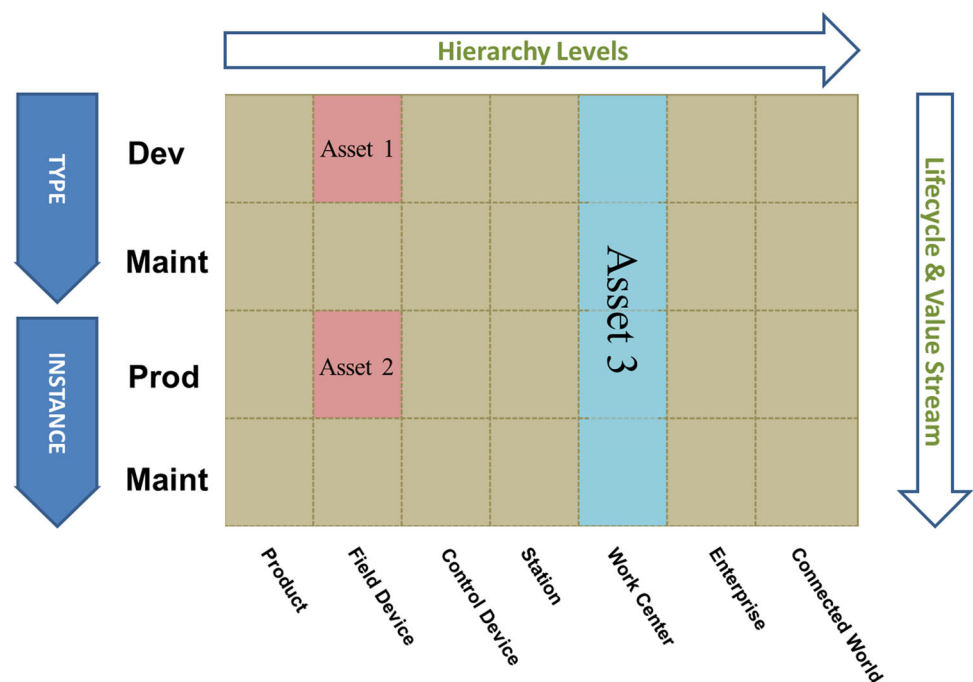


Fig. 2 Digital Twin design process

Fig. 3 Mapping assets over a RAMI 4.0 architecture layer: an example



in RAMI 4.0, assets are treated in the entire lifecycle, from their prototype (*Type*) during development (Dev) or maintenance (Maint), to their *instance*, when they are deployed in production, and during their maintenance process. Figure 3 depicts a generic example of applying this process over a single RAMI 4.0 layer.

According to [23], the view is constructed by tagging the security properties of each asset inventoried in the RAMI 4.0 framework. Thus, the view is obtained by simply performing a top-down projection (from Business down to Asset layer) extracting the items who have the “Security” tag. Notably, the same procedure can be applied to any other framework.

4.3 Phase 2: deriving the cybersecurity digital twin

There are various formal languages that can be used to represent the digital twin of a physical system [4,7,39]. For our purpose, the relevant architectural assets and the relationships among them are represented using the Meta Attack Language MAL [40], which is suited for security application and, more specifically, for visual attack simulation and threat modeling. Moreover, MAL provides built-in structures (in the form of graphs) that also allow to model the domain itself.

To derive the cybersecurity DT from the cybersecurity view generated by Phase 1, the relevant architectural assets and their relationships should be represented in MAL. There-

fore, we defined the target model using SecuriCAD,⁸ which is the visual editor for MAL. SecuriCAD comes with a set of predefined objects that can be used for the creation of the IACS model. The following objects are used:

- *Components*, such as clients (ssh clients, generic in house-built, GPL, or COTS components), or keystores, to hold secrets. *Access control systems* are also represented as components;
- *Hosts*, grasping the peculiarities of the operating system (e.g., Windows or Linux). Hosts can be considered patched and hardened, or unsupervised and unpatched. Typical unpatched hosts are CCTV cameras, while hardened systems could be workstations in a control room;
- *Data flows, firewalls, and protocols* representing the details around the system communications. Data flows also represent *zones* and *conduits* or *protection rings* à la ISO 27002, which can be either physical or logical;
- *Zones*, representing a group of assets that share the same risk according with [41];
- *Twin Concept*. This latter object is not part of the MAL specifications. In fact, we added this layer to group information about the threats and the assets to protect. The norm [41] requires asset owners to perform an high level risk analysis or a business impact analysis to define the target security level for each specific zone. Those results are typically added in the Business layer of the framework. We then use the information provided to simulate the attack paths toward the assets of high importance.

The graph resulting from the translation of the Cybersecurity View into MAL represents the DT, where we can apply the business reasoning, evaluating risk exposure scenarios vs. protection costs. As part of the mapping, all *assets* and *integration* layers can be either components or hosts. This depends on their maturity or on their inherent characteristics. For instance, a device that has an off-the-shelf operating system is a host, while a PLC is a component. The *communication* entries are in the *data flows* and in the *protocols*, while the *information* components become part of the cybersecurity DT (in the *Twin Concept*), since the information has to be protected in any case. *Functionalities* are then related both to *protocols* and to *zones*, as per IEC 62443 standards for the safety and security of industrial control systems, while business considerations tell us “what to model” and what should go into the DT in the *Twin Concept*. It is important to stress that no system implementation details are part of the model, as they do not represent architectural assets. Our analysis is focused on architectural components. Other instruments and procedures exist to evaluate thoroughly cybersecurity

aspects of a specific implementation, such as Static Analysis Software Testing or specialized formal methods.

4.4 Phase 3: security simulations and countermeasure identification

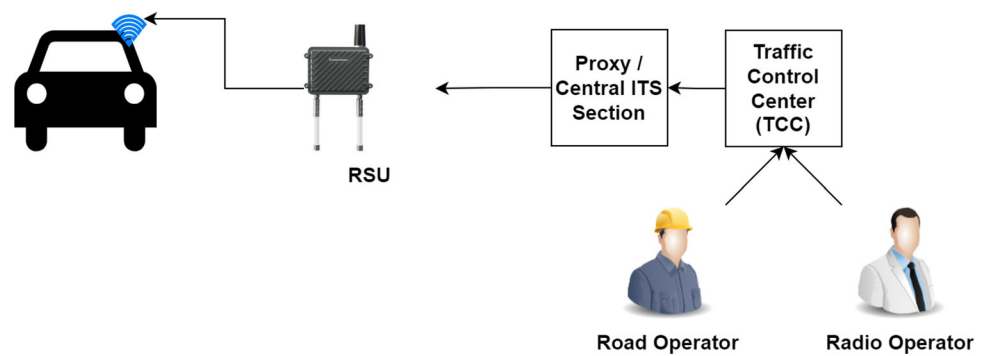
As described in the previous section, we use SecuriCAD as a tool for threat modeling and simulations on the DT. The DT may already contain objects meant to function as security countermeasures (e.g., firewalls). However, in order to perform a business-oriented security reasoning, it is advisable to carry out some attack scenarios first, which may have higher business impact. In case of a new system, with no history of previous threats, we can rely on the canonical attacks described in [42]. For an existing system, we can perform risk analysis and borrow from the attack tactics for Industrial Control Systems listed in the MITRE ATT&CK for ICS knowledge base [43]. Additional sources can also be used to assess cybersecurity risks and specific attack scenarios for a particular context.

Once the attack scenarios are identified, the attack simulations are run with SecuriCAD. The outcome of the simulation is the likelihood of attack success. A business decision is then to be made on whether the modeled security posture is cost-effective and acceptable for the given scenario. If not, the security expert shall iterate over the countermeasures and re-run simulations until an acceptable solution is found, for all the attack scenarios. The impact on the system architecture is fed back into a prescriptive blueprint and transferred to the real system.

Although the methodology presented here relies on standard-based methods and follows a structured approach, a significant portion of its implementation relies on human input. For instance, the reverse engineering of an existing IACS and the definition of business requirements (such as risk appetite) are dependent both on the expertise of practitioners and on the organizational context where it is applied. This may be a limiting factor in reproducing the implementation steps and the results of the methodology, as well as in practically adapting it as part of an organization’s change management. To mitigate such limitations, we take an architecture-based approach to develop its constructs, using high-level description language. This makes its implementation easier to understand for a non-technical person as well, enabling richer collaboration between technical experts and business decision makers in achieving cost-effective security postures, with acceptable risk levels. Finally, it is important to point that while we do not claim general applicability of our methodology to every critical infrastructure, we believe it to be widely applicable in the field of cybersecurity of IACS supporting critical infrastructures.

⁸ See <https://www.foreseeti.com>.

Fig. 4 C-ITS system architecture for a road operator



5 Use cases: critical infrastructures

To demonstrate the practical feasibility of our methodology, we apply it to two different real-life use cases in the field of Critical Infrastructures, where compliance with cybersecurity requirements, especially with respect to *availability* and *safety*, is also legally mandated. The first use case deals with a Cooperative Intelligent Traffic Systems (C-ITS) and illustrates the *security-by-design* aspect of the methodology when it is applied to a new system, as described in Sect. 4. The second use case deals with legacy road tunnels and their control systems. It also follows the “*mapping from a real system*” approach, proposed in the methodology as a means to derive an initial model of the system. It is important to note that both use cases are based on real-world scenarios from a Motorway Operator. Notably, the two use cases are representative for the Critical Infrastructure, as the C-ITS are referenced as “Essential Service” by the NIS Directive (EU 2016/1148, Annex 2, 2(d)) and the Road Tunnels are considered Critical Infrastructure by the US Department of Homeland Security.⁹

5.1 Use case 1: cooperative-intelligent traffic systems

Road transportation systems are one of the key enablers for a thriving economy and sustainable development. Their functioning fully and uninterrupted is thus critical for the society in general. However, the traffic volume has been steadily increasing, demanding for the deployment of specific equipment to support and enhance the traveling experience of the road user, while providing safety of the road infrastructure itself, lowering the carbon consumption, or complying with other legal, environmental and societal requirements. Furthermore, vehicles are being endowed with smart technology to increase the safety of the car drivers and passengers, for, e.g., by using more sophisticated equipment, updating

the communication protocols, etc. These elements, the vehicle and the road infrastructure, together with the messages exchanged between them (either from the vehicle to the road or vice versa), are part of a bigger ecosystem named the Cooperative Intelligent Transport system (C-ITS).

5.1.1 Phase 0: building a solution architecture of the C-ITS

The C-ITS Solution Architecture is mainly based on the hub-and-spoke paradigm [17,18], where a central system carries the messages to the Road Side Units (RSUs) located on the motorway. The communication between the vehicle On Board Unit (OBU) and an RSU is usually performed via radio waves [44]. A traffic control center (TCC) collects the events from the road that, in turn, are forwarded to an agent who knows for which specific subset of RSUs the event is relevant (e.g., an event about road works 500 km away will not be relevant). This agent, named *proxy*, plays the role of a Central ITS-Station, while the RSUs are named ITS-Stations. The high level architecture of this system is shown in Fig. 4.

Road Operators notify the TCC about the event (e.g., road works, slippery road) or a Radio Operator is notified by other sources (e.g., other road owners or infrastructure). It also notifies the TCC, who decides the relevance of the event and prepares the message to be propagated to the RSU network. The OBU and the vehicle cooperate with the ITS by acting upon the information received, via DENM¹⁰ messages and by sending their sensed data back to the TCC. Security properties are Confidentiality (as the message may contain geographical information and license plates [42]), and Availability (as per 62443-1-1). Those are the security properties to be tagged.

5.1.2 Phase 1: generating a cybersecurity view

Applying Phase 1 of the process presented in Sect. 4.2, the EA of the system can be represented as follows.

⁹ See, <https://www.dhs.gov/science-and-technology/critical-infrastructure>. Usually countries maintain a list of Critical Infrastructure which is kept confidential.

¹⁰ Decentralized Environmental Notification Message.

- *Asset Layer*: it contains the devices such as RSU, Proxy, and TCC, software and the networking assets. Those devices have to preserve both Confidentiality and Availability, and thus, they will be tagged;
- *Integration Layer*: we leave it empty, as per [23], as all the components in the C-ITS architecture fulfill the Industry 4.0 dictates of connectivity;
- *Communication Layer*: it contains the protocols (e.g., [44–46]) used to exchange data between the assets. Those protocols have to preserve both Confidentiality and Availability;
- *Information Layer*: it contains the syntactical definitions and implementations of the data exchanged [47];
- *Functional Layer*: it contains the description of the process of exchanging a C-ITS message, e.g., where a Radio Operator injects the information in the TCC. The descriptions of the functionalities have to preserve both Confidentiality and Availability;
- *Business Layer*: it contains the business information telling us what to protect, e.g., the security zones, and the availability requirements of the critical services, such as TCC, or the Central ITS-S. That information will define the high value assets to protect while simulating.

All the architectural assets now categorized in the RAMI 4.0 layers, are now tagged with the respective cybersecurity properties. The cybersecurity view is then constructed by projecting all the assets tagged and performing the mapping as per Sect. 3.2.

5.1.3 Phase 2: deriving the cybersecurity digital twin

Here, we describe a practical application of the methodology to evaluate the Cybersecurity Digital Twin for C-ITS using MAL and the SecuriCAD tool.

By performing Phase 2 as described at the end of Sect. 4.3, we obtain a model with three logical zones, as depicted in Fig. 5.

The first is the Traffic Control Center (attached to the Corporate Network), represented by the host TCC. The host comes from the asset layer of the system's EA, that has a client named TCCBatch, which is responsible to forward the DENM's to the Central ITS Station. Attached to the network is the Laptop Maintainer, which belongs to the system administrator connected to all other hosts via *ssh*. The second zone is the Proxy/Central ITS Station, represented by its host and two streams: the downstream from the TCC ProxyBatch, which is receiving the DENMs for processing, and the upstream to the RSU, composed by a client Proxy and a service, based on Apache Kafka technology, to receive the CAMs. The third zone, the Road Side Units, are placed on the motorway (represented by its Physical zone) where the

RSU host (a Linux system) runs a BXC, an in-house software that processes the CAMs and DENMs. Finally, the communication and information aspects (protocols and data flows) are represented in the data flow section. The “star” present in some of the components represents the functional and business layers, e.g., the functionalities and the high value business objects that have to be protected. This model also represents the EA as described in Sect. 5.1. The two other components shown in the Figure are the central firewall and the VPN of the RSU.

5.1.4 Phase 3: security simulations and countermeasure identification

To perform the simulation (see Phase 3 in Sect. 4.4), the attacker is placed in the physical zone. This is done in order to check the security of the EA by reasoning over the system representation. The countermeasures that will be used to protect the functionalities of the business objects are defined by discovering attack trees and the likelihood that a specific asset could be compromised.

In this case, for the sake of presentation, we assume the business reasoning identified three canonical attack scenarios that have considered to be of high impact (CITS1, CITS2, and CITS3), in which the attacker compromises either the IT network or the RSU network, or targets both the IT and the RSU services. We did not carry out a detailed risk analysis, so we relied on the canonical attacks that we borrowed from [42], as the system is new and there is no past history of specific risks, except for canonical ones.

Table 2 shows the reasoning used to lower an initial high risk ($> 60\%$) to a medium level ($30\% \leq \text{risk} < 59\%$) and then to low ($< 29\%$), which has previously been determined as an acceptable value. Risk percentages are evaluated by SecuriCAD simulations. We refer the interested reader to [48].

In scenario CITS1, the attacker connects to the Corporate Network as in Fig. 5. Without any countermeasures (as defined in the first version of the EA, column *Without Countermeasure (CM)*), the attacker can reach the IT services (TCC and Central ITS Station) with a very high probability. The addition of a central firewall, as shown in Fig. 5, would reduce reachability (column *with CM*), but the attack is still possible (with a medium risk), since the attacker can exploit a path compromising unpatched/zero day known protocols (*ssh*). The results of these simulations provide feedback to improve the EA, resulting in the addition of a Central Firewall among the EA's assets. This new version of the EA is used to simulate CITS2, positioning the attacker in the maintainer laptop, targeted at compromising the RSU. The result is again medium (comparable to the CITS1 with the firewall) as there is no additional countermeasure. By adding an Intrusion Detection Systems (IDS), like an antivirus, and a

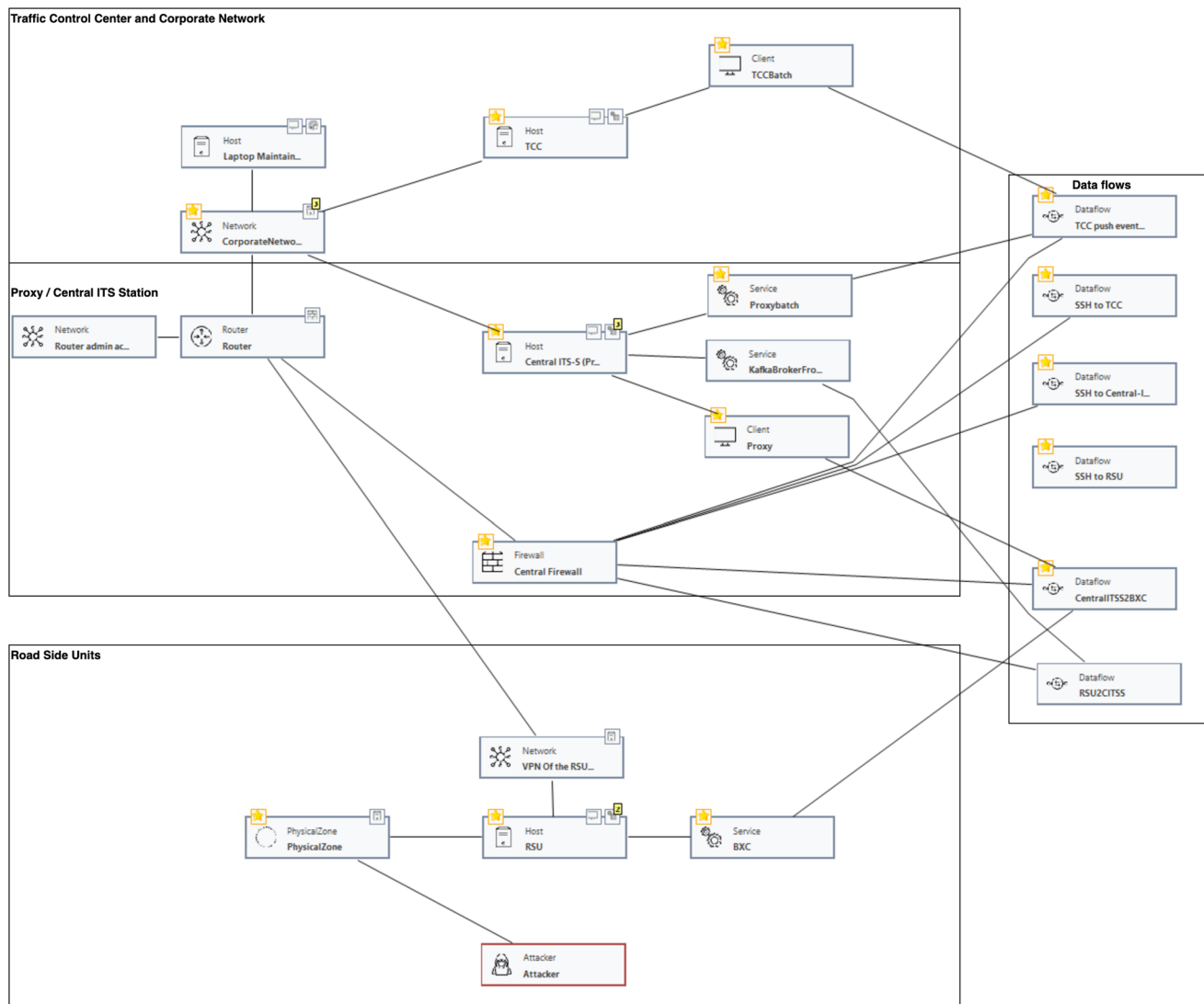


Fig. 5 The cyber security digital twin of the C-ITS

Privilege Access Management (PAM) as a Secure Remote Access (thus monitoring and controlling all accesses) we can lower the risk to an acceptable level (23%), leaving the attacker to compromise the in-house software with a very low likelihood. As previously, we provide feedback to the EA and start simulating CITS3. In this scenario, the attacker has physical access to the RSU and wants to compromise all other RSUs. We added to the model another copy of the RSU component and run the simulation. The countermeasures found for CITS2 are sufficient for CITS3, so there is no difference in the risk scoring by adding a local firewall on the RSU network. Through simulations and modifications, we were able to derive a new version of the EA for the system, to perform gap analysis and to prove the cost-effectiveness

of adding/not adding some specific solutions (IDS, Firewall, PAM).¹¹

It is important to note that C-ITS data, although exchanged directly with the vehicles, is also indirectly exchanged with the entire C-ITS system. Hence, this application context resembles an open system in which data traverse a single road transportation environment, flowing toward other road operators and even other different critical infrastructures. For, e.g., Smart Cities, hospitals and fire brigades all consume traffic data when defining alternative traffic routes to be followed by the ambulances for carrying patients, or to arrive to a site in case of accidents. In that sense, the methodology presented here is also applicable for a setting where the interdependencies between various critical infrastructures may

¹¹ All the sample files created are available at <https://github.com/mascanc/mascanc>.

Table 2 Attack scenario

Attack ID	Description	Without CM (%)	With CM (%)	Mitigation
CITS1	The attacker is connected to the corporate network and compromise the Central ITS-S and the TCC	69	46	Adding a Firewall as countermeasure reduce the risk, since it attacks are possible only on allowed protocols and lateral movements are limited. Additional countermeasure: systems have to be patched continuously
CITS2	The attacker compromise the maintainer's laptop and then compromise the RSUs	50	23	Still with the Firewall, attacks are possible. Adding IDS, Privilege Access Management, the attack goes still through sshd and then needs to find an exploit to the in-house software BXC
CITS3	The attacker perform a physical access to the RSU and compromise other RSUs	30	30	With the same countermeasures as CITS1 and CITS 2, the mitigation are sufficient to have a low risk of compromise

lead to cascading effects, since the consequences deriving from malfunctions or cyber-physical attacks on one critical infrastructure can affect all the other inter-connected ones.

5.2 Use case 2: road tunnel

Similar to Sect. 5.1, we will first set the cybersecurity context of a road tunnel by analyzing the general context of the system.

Road tunnels, specially those located in motorways, are considered critical infrastructures. The EU Directive 2004/54/EC [49] prescribes a minimum level of safety for road users in tunnels through the prevention of critical events that may endanger human life (such as fire) and the environment, such as the transportation of dangerous goods [50–52]. Motorway concessionaires and Road Authorities shall perform detailed risk analyses to determine the acceptable level of protection for each tunnel [53]. To prevent and protect road users from injuries and death, and to mitigate the risk related to them, IACS are formed by a set of actuators, sensors, Programmable Logic Controllers (PLC), and a SCADA system automating the physical safety countermeasures. A typical tunnel IACS is composed of an electrical power supply and distribution, indications of emergency exits, ventilation, signaling, video surveillance, fire detection, emergency call network, and air quality control [22], as depicted in Fig. 6.

Outside of the tunnel there are shelters, hosting PLCs and the SCADA system. The control room is usually situated several kilometers away from the tunnel, continuously monitoring the status of the IACS. It is worth noting that in case of severe accidents, the IACS is designed to run without human intervention, even physically disconnected from the control room. This is done by actuating the fans, pressurizing the

bypass, and turning on electronic emergency lights after a fire detection sensor triggers. This procedure is crucial from a cybersecurity point of view; on the one hand, the metrology chain has to be secured [54] so that false positives are correctly treated and the messages forged across PLC devices traveling the IACS network must be detected and reported immediately as security incidents. In fact, if the tunnel IACS is triggered during normal traffic conditions due to a cyber-criminal forging sensor messages, it may cause injuries and collisions among vehicles. Moreover, erroneous application of the ventilation engines in case of fire can let the temperature inside the tunnel to rise up dramatically, altering the safety measures of the bypass and damaging the tunnel for a long time [55]. By nature, a tunnel connects two sites physically separated by geographic obstacles (mountains, rivers, sea, etc.); hence, a malfunctioning tunnel leads to economic loss and pressure over other infrastructures lying on both sides of the entrance, making them a possible target for (cyber)terrorist attacks [56].

These examples clearly demonstrate the need for adequate cybersecurity measures in a tunnel IACS. The IACS described in this section is only a generic schema. Every tunnel has its own schema instance, depending on its physical characteristics and IACS design.

Creating a secure environment would require, according to IEC 62443 [41], a detailed risk analysis for each component of each IACS. Usually tunnels are operated by either a governmental agency or by a concessionary, who have dozens, if not hundreds of tunnels under control. This means that performing risk analysis for each equipment requires huge and continuous efforts. With the methodology proposed in this paper, we enable the creation of a digital twin for each tunnel and facilitate the threat modeling, while analyzing the

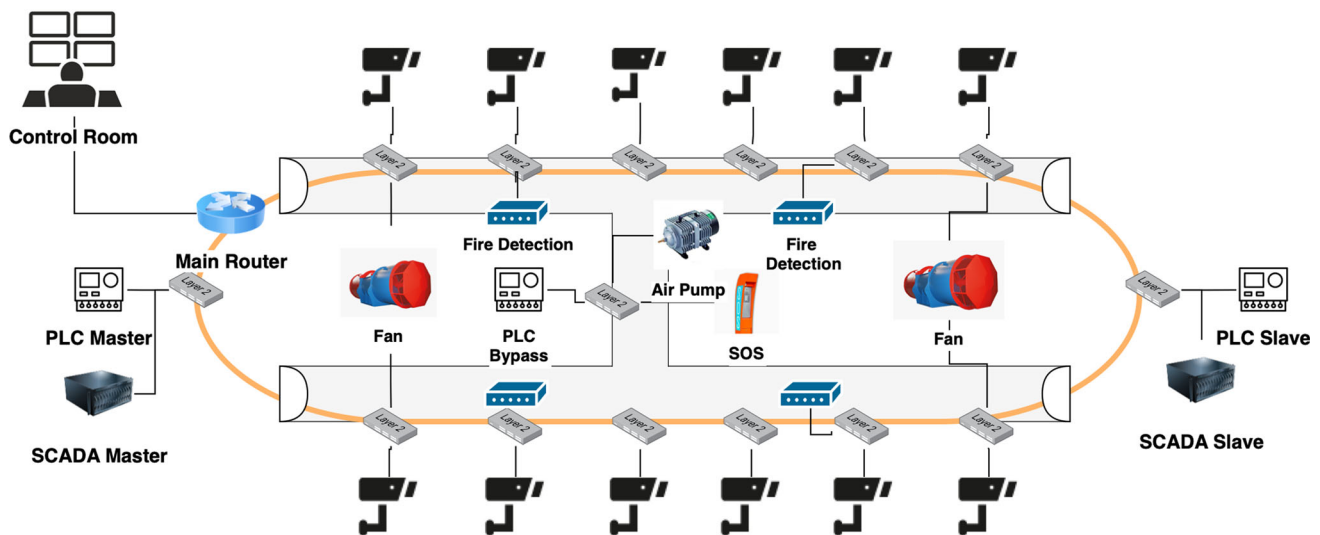


Fig. 6 Schema of a tunnel's IACS

effectiveness of countermeasures without requiring complex test laboratories or closing the tunnel to traffic.

5.2.1 Phase 0: building a reference architecture of the road tunnel

Differently from Sect. 5.1.1, here the system under analysis already exists, but we do not have a suitable architectural model of it. Thus, we need to approach it by mapping its real components, business process and company procedures into the RAMI 4.0 framework and layers. This allows us to identify and output in a structured way both the countermeasures and the control processes of the IACS. It also enables a gap analysis based on the concept of *target* profile (the desired security posture). Notably, this is a generic template of a Road Tunnel; thus, we can consider it as a Reference Architecture. We start by checking the status of the NIST controls, i.e., how (and if) each of them is adequately implemented. Since performing technical controls requires on-site visits, to perform, e.g., control ID.AM-3—*Data flows are mapped*, we sniffed the data traffic on the network switches. By systematically checking all the controls recommended by the framework, we reached the current security posture of the tunnel, including asset management, protection, and detection tools.

5.2.2 Phase 1: generating a cybersecurity view

After performing all the activities outlined in Sect. 5.2.1, we are now able to map the NIST control outcomes over the RAMI 4.0 layers (Phase 1 of the methodology described

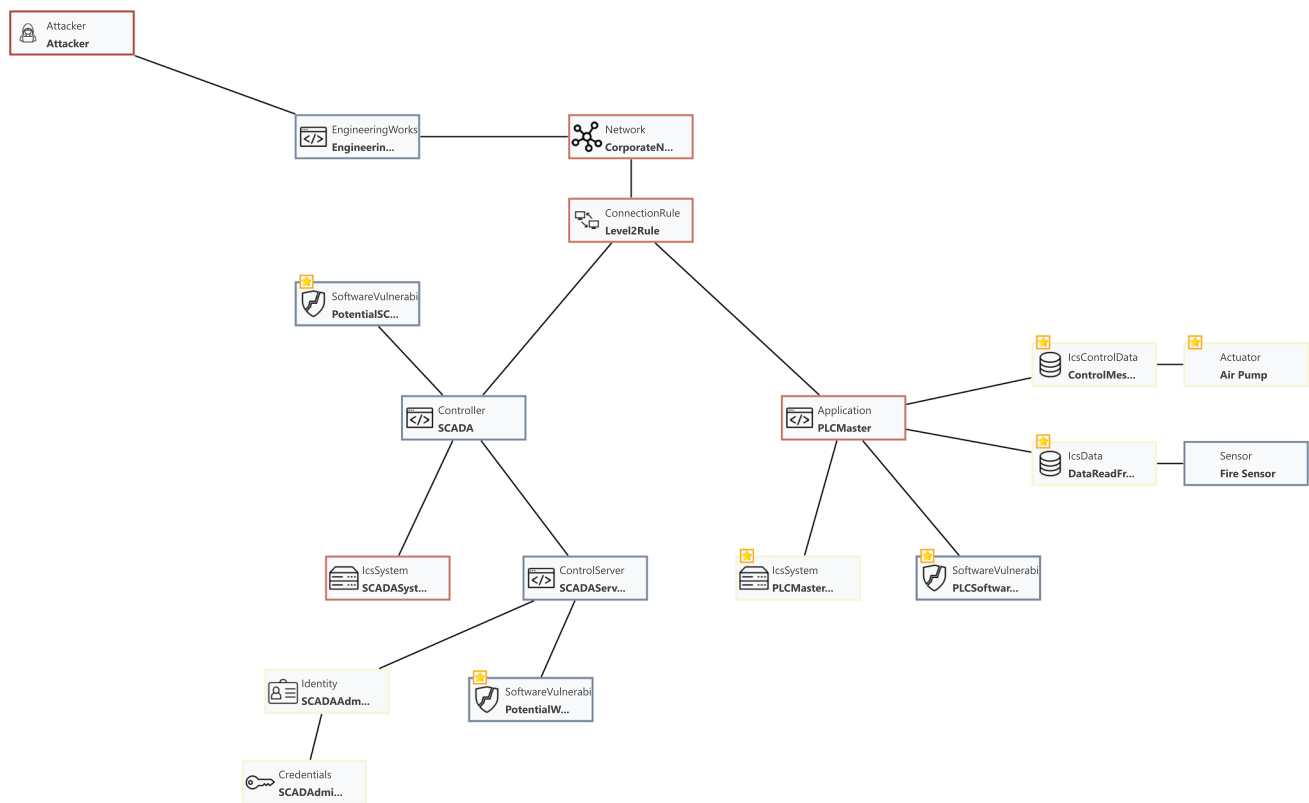
in Sect. 4.2).¹² As a result, the assets inventoried while performing the tasks related to the NIST ID.AM-1 control become part of the *Asset* layer, while the protocols mapped in ID.AM-2 and ID.AM-3 are then part of the *Communication* and *Information* layers. *Functional* and *Business* layers contain the high level policies and company processes identified in the other controls. Concretely, PLCs are part of the Asset/Field Device/Type Usage coordinate, while SCADAs are in Asset/Control Device/Type Usage. Control rooms are part of the Work Centers, while the protocols defined between the PLCs and the SCADA (typically Modbus/TCP) are mapped in Communication/Control Device/Type Usage. The ventilation algorithm is placed in the Functional layer, and the process of handling suppliers in the Business layer.

Table 3 details the inventory of the assets over the RAMI 4.0 cube. The *Name* column corresponds to the schema reverse engineered as described in Sect. 5.2.1. The mapping of each item over the RAMI 4.0 cube is as follows: The color respects the RAMI 4.0 *layer* color coding (vertical axis); column *RAMI coordinate* provides the coordinates over the two other axis. The *NIST* column shows the relevant NIST sub-category and, lastly, the *MAL* column shows the pre-defined objects for this model (in brackets, the names used in the previous model). These objects shall be the components of the Digital Twin described in the next section. With respect to the general model, for the sake of readability, only an excerpt of the entire model is shown here. The table also contains the tags needed to build the cybersecurity view as superscript to the asset name (A stands for Availability, I for Integrity). Regulations described in Sect. 5.2 require Availability as a mandatory property for all the IACS's assets, while Integrity

¹² Using the NIST framework in conjunction with RAMI 4.0 is detailed in [38].

Table 3 Excerpt of cybersecurity view of the tunnel's IACS

Name	RAMI coordinate	NIST	MAL
PLC Master ^A	Asset/ControlDevice/Inst Prod	ID.AM-1	IcsSystem (Host)
Air Pump ^{A,I}	Asset/FieldDevice/Inst Prod	ID.AM-1	Actuator (Component)
Fire Sensor ^{A,I}	Asset/FieldDevice/Inst Prod	ID.AM-1	Sensor (Component)
SCADAServer ^A	Asset/Station/Inst Prod	ID.AM-1	ControlServer (Host)
Control Room PC ^A	Asset/Station/Inst Prod	ID.AM-1	Engineering Workstation
<i>Integration Layer (empty)</i>			
Modbus/TCP ^{A,I}	Comm/ControlDevice/Inst Prod	ID.AM-2	ConnectionRule Level2 (DataFlow)
Control Messages ^{A,I}	Information/FieldDevice/Inst Prod	ID.AM-2	ICSControlData (Data)
Data Read From Sensors ^A	Information/FieldDevice/Inst Prod	ID.AM-2	ICSControlData (Data)
Emergency Operation of the Tunnel ^A	Functional/ControlDevice/Inst Prod	ID.AM-3	Starred assets
Tunnel operation, compliance ^A		ID.AM-3	Starred assets

**Fig. 7** The digital twin of the tunnel without countermeasures

is a property required for the message flow, as a manipulation of a message is a typical attack that would add unknown traffic in the control network, eventually causing system crashes.

5.2.3 Phase 2: deriving the cybersecurity digital twin

The *Identify function* in NIST cybersecurity framework includes categories like ID.RA (risk assessment), ID.RM (risk management strategy) and ID.SC (supply chain risk

management). Since there is no standard or risk catalogue specific for road tunnel IACS, we identified risks based on: (i) on-site visits, (ii) the MITRE ATT&CK for ICS knowledge base [43] and (iii) the results from the findings of the working group on Industrial Control System cybersecurity [22]. Other sources and knowledge bases can also be used.

The on-site visits showed potential risks related to physical access to the shelters and to their switches, as well as a number of security vulnerabilities for the specific versions of

Table 4 Attack scenarios

Attack ID	Description	Without CM (%)	With CM (%)	Mitigation
TUN1	The attacker is impersonating the SCADA user	100	29	Without any protection, the attacker impersonating the SCADA user can have full access to the PLC. Adding an IDPS on the SCADA and a firewall on the OT network, it mitigates the lateral movements
TUN2	The attacker compromise the maintainer's laptop and then compromise the PLC	100	12	Without any protection, the attacker can exploit the full network access of the workstation, scan the network, obtain access to the PLC and exploit the vulnerabilities. By adding a segregation, e.g., a Connection Rule which is connecting two networks with a firewall, the attacker cannot move laterally

Notably, we use the same risk appetite as for Sect. 5.1

the PLCs, which may be exploited in the wild. We then tailored the risks and the tactics identified in the MITRE matrix to the posture of the tunnel. For example, MITRE defines a potential initial access as *Exploiting Public-Facing Applications*, in which an intruder can search in websites (such as shodan.io) for applications that are exposed to internet and to the IACS at the same time. To discover such exploits, we checked the source and destination IP addresses of the captured network packets referenced in the previous section, in order to find potentially anomalous traffic. Similarly, the *Replication Through Removable Media* has been identified by checking the availability of USB ports in the servers, and the internal company policies to search for a possible process in which the usage of USB drives would be not allowed in the IACS tunnel zone.

To maximize the impact of cybersecurity measures, decisions are also made regarding the Safety and Availability requirements for the system. For instance, although redundancy of the system is mandatory and failures are tolerated up to a certain limit [53], a trade-off should also be made between usability and safety [57].

5.2.4 Phase 3: security simulations and countermeasure identification

By following Step 2 (see Sect. 4.3), we have obtained the cybersecurity Digital Twin depicted in Fig. 7. In this case, we model a single, flat network in MAL with SecuriCAD, which will also evolve with the set of countermeasures. According to Step 3 (Sect. 4.4), in order to model specific risks we added potential vulnerabilities representing possible zero days, which are common in IACS.

Similarly to the C-ITS use case (Sect. 5.1.3), we identify two attack scenarios as described in Table 4. In the first

attack scenario, TUN1, the attacker has found a leak—the credentials of a SCADA user without 2-factor authentication. The attacker then tries to impersonate the user, accessing the SCADA in the regular way and causing a denial of service over the PLC algorithm. In the second attack scenario, TUN2, the attacker compromises a maintainer laptop. In this case we want to model an attack that comes from a regular device, e.g., originating from a disgruntled employee or an advanced persistent threat.

The results in Table 4 show that it is a highly recommended practice to segregate the IT and OT networks, and especially the control networks, to avoid lateral movements. For example, adding an Intrusion Detection and Prevention System (IDPS) (such as a next generation firewall that checks the packets for their plausibility and a host-based antivirus checking for USB devices), will drop the packets not conforming to the IACS requirements. The countermeasures and the positioning of the attacker have been identified by the risk analysis carried out in Sect. 5.2.3. In fact, in our model, we curtail the use of *Replication Through Removable Media* technique¹³ by adding the IDPS on the SCADA and the Maintainer, while the high value assets have been identified by the impacts.

Considering the computational aspects of the simulations presented above, it is important to note that as the simulations rely on a constrained set of attack techniques (coming from the SecuriCAD database), no assumptions can be made with regards to the attacks that are not known. Therefore, in the effort to mitigate this constraining factor, we have employed the MITRE ATT&CK matrix [43] for Industrial Control Systems as our catalog for strategies, techniques, and procedures for the use cases. However, MITRE does not claim that the matrix guarantees full defensive coverage as there may be

¹³ See <https://attack.mitre.org/techniques/T1091/>.

undisclosed techniques or variations on existing techniques which are not documented.

6 Conclusion and future work

In this paper, we proposed a methodology for designing a security-oriented Digital Twin for cyber-physical critical systems, following an architectural security-by-design approach. The architectural approach can include cybersecurity concerns for both existing and new projects/systems. It results in a catalogue of assets to be protected, organized into an architecture view specified by a cybersecurity architecture viewpoint, and allows for the identification of a set of adequate countermeasures depending on the chosen security posture. At the same time, the methodology follows standard procedures and frameworks, ensuring the fidelity of the designed Digital Twin.

The cybersecurity viewpoint mentioned above was designed to facilitate a consistent implementation by practitioners. It provides straightforward modeling rules and constraints applicable to system design and operation phases alike. In addition, relevant guidelines and suggestions are given regarding the use of the NIST security controls as a complementary part of the methodology when addressing some security aspects specific to existing critical infrastructure systems.

This methodology was applied to two real-world use cases of critical infrastructures: a Cooperative Intelligent Transport System (C-ITS) and the Industrial Automation and Control System of a road tunnel. We defined typical cyber-attack scenarios and identified countermeasures for risk-mitigation in each scenario. Feeding back the results into the architecture model, we modified it to achieve an acceptable level of risk. In this way, we demonstrated that using a DT, tasks such as vulnerability assessment and security testing can be performed without causing any service interruption in the running system. For this reason, the effectiveness of countermeasures elicited in Sect. 5 has not been validated through typical Penetration Testing, as this would have required a potential unavailability of the C-ITS services and Tunnel IACS, which is not possible for a Motorway Operator as Autostrade Per L'Italia.

Although MAL and SecuriCAD have shown to be powerful tools for our purpose, they are currently not able to capture a detailed-level system representation. For instance, the protocol-specific risks and device peculiarities have not been taken into account. Therefore, as a future work, we aim to define a way of grouping the architectural assets in order to automatically determine the specifications of the digital twin components that can be reused. This will also result in more efficient modeling process. Moreover, we aim at making the target modeling language parametric as well, to avoid

vendor and standard lock-in. To mitigate the risk of not having regulations or communities continuously evaluating the IACS of Road Tunnels, we plan to share the results of our simulations and the risk analyses (specially in Sect. 5.2.1) with the relevant bodies, such as the European Union Agency for Cybersecurity (ENISA) and the World Road Association (PIARC).

Finally, the concept of Enterprise Cartography will be investigated in the effort to improve and formalize the mapping of the observed items of the legacy systems onto a given taxonomy. This will further facilitate the work of the system architects, whose expertise can be considered as a scarce resource.

References

1. NIST: Cybersecurity Framework (2021). <https://www.nist.gov/cyberframework>
2. Sellitto, G.P., Masi, M., Pavleska, T., Aranha, H.: A Cyber security digital twin for critical infrastructure protection: the intelligent transport system use case. In: Serral, E., Stirna, J., Ralyté, J., Grabis, J. (eds.) *The Practice of Enterprise Modeling—14th IFIP WG 8.1 Working Conference, PoEM 2021, Riga, Latvia, November 24–26, 2021, Proceedings. Lecture Notes in Business Information Processing*, vol. 432, pp. 230–244. Springer, Cham (2021). https://doi.org/10.1007/978-3-030-91279-6_16
3. Sellitto, G.P., Aranha, H., Masi, M., Pavleska, T.: Enabling a zero trust architecture in smart grids through a digital twin. In: Adler, R., Bennaceur, A., Burton, S., Salle, A.D., Nostro, N., Olsen, R.L., Saidi, S., Schleiss, P., Schneider, D., Schwefel, H. (eds.) *Dependable Computing—EDCC 2021 Workshops - DREAMS, DSOGRI, SERENE 2021, Munich, Germany, September 13, 2021, Proceedings. Communications in Computer and Information Science*, vol. 1462, pp. 73–81. Springer, Cham (2021). https://doi.org/10.1007/978-3-030-86507-8_7
4. Jones, D., Snider, C., Nassehi, A., Yon, J., Hicks, B.: Characterising the digital twin: a systematic literature review. *CIRP J. Manuf. Sci. Technol.* **29**, 36–52 (2020). <https://doi.org/10.1016/j.cirpj.2020.02.002>
5. Pokhrel, A., Katta, V., Palacios, R.C.: Digital twin for cybersecurity incident prediction: a multivocal literature review. In: *ICSE '20: 42nd International Conference on Software Engineering, Workshops, Seoul, Republic of Korea, 27 June–19 July, 2020*, pp. 671–678. ACM, New York (2020). <https://doi.org/10.1145/3387940.3392199>
6. Fuller, A., Fan, Z., Day, C.: Digital twin: enabling technologies, challenges and open research. *IEEE Access* **8**, 108952–108971 (2020)
7. Dietz, M., Vielberth, M., Pernul, G.: Integrating digital twin security simulations in the security operations center. In: *Proceedings of the 15th International Conference on Availability, Reliability and Security. ARES'20. Association for Computing Machinery, New York (2020)*. <https://doi.org/10.1145/3407023.3407039>
8. Talkhestani, B.A., Jazdi, N., Schloegl, W., Weyrich, M.: Consistency check to synchronize the digital twin of manufacturing automation based on anchor points. *Procedia CIRP* **72**, 159–164 (2018). <https://doi.org/10.1016/j.procir.2018.03.166>. (51st CIRP Conference on Manufacturing Systems)
9. Eckhart, M., Ekelhart, A.: In: Biffl, S., Eckhart, M., Lüder, A., Weippl, E. (eds.) *Digital Twins for Cyber-Physical Systems Security: State of the Art and Outlook*, pp. 383–412. Springer, Cham (2019). https://doi.org/10.1007/978-3-030-25312-7_14

10. Eckhart, M., Ekelhart, A.: Towards security-aware virtual environments for digital twins. In: Proceedings of the 4th ACM Workshop on Cyber-Physical System Security. CPSS'18, pp. 61–72. Association for Computing Machinery, New York (2018). <https://doi.org/10.1145/3198458.3198464>
11. Korman, M., Vålja, M., Björkman, G., Ekstedt, M., Vernotte, A., Lagerström, R.: Analyzing the effectiveness of attack countermeasures in a SCADA system. In: Proceedings of the 2nd Workshop on Cyber-Physical Security and Resilience in Smart Grids, SPSR-SG@CPSWeek 2017, Pittsburgh, April 21, 2017, pp. 73–78. ACM, Cham (2017). <https://doi.org/10.1145/3055386.3055393>
12. Energy Shield: Developing the cyber toolkit that protects your energy grid (2021). <https://energy-shield.eu>
13. Damjanovic-Behrendt, V.: A digital twin-based privacy enhancement mechanism for the automotive industry. In: 2018 International Conference on Intelligent Systems (IS), pp. 272–279 (2018). <https://doi.org/10.1109/IS.2018.8710526>
14. Franke, U., Cohen, M., Sigtholm, J.: What can we learn from enterprise architecture models? An experiment comparing models and documents for capability development. *Softw. Syst. Model.* **17**(2), 695–711 (2018)
15. Jacob, M.E., Meertens, L.O., Jonkers, H., Quartel, D.A.C., Nieuwenhuis, L.J.M., van Sinderen, M.J.: From enterprise architecture to business models and back. *Softw. Syst. Model.* **13**(3), 1059–1083 (2014)
16. The European Parliament and the Council of European Union: Directive (EU) 2016/1148. NIS Directive (2016)
17. United States Department of Transportation: Intelligent Transportation Systems, Joint Program Office (2021). <https://www.its.dot.gov/>
18. ICT4CART: A connected future for automated driving (2021). <https://www.ict4cart.eu>
19. Smart Grid Coordination Group: Smart Grid Reference Architecture. Technical report, CEN-CENELEC-ETSI (2012)
20. Integrating the Healthcare Enterprise: The IHE IT Infrastructure Technical Framework. Standard, IHE (2019)
21. Health informatics—IHE global standards adoption—Part 1: Process. Technical report, International Organization for Standardization, Geneva, CH (2014)
22. Agence Nationale de la Sécurité des Systèmes d'Information: Practical Case of a Road Tunnel—Part 1: Classification (2014). <https://www.ssi.gouv.fr/uploads/2017/09/anssi-ics-tunnel-case-study-part-1.pdf>
23. E.V., D.I.F.N.: DIN SPEC 91345 Reference Architecture Model Industrie 4.0 (RAMI4.0). Technical report, DIN (2016)
24. The Open Group: TOGAF 9.2 (2019). <https://www.opengroup.org/togaf>
25. Uslar, M., Rosinger, C., Schlegel, S.: Security by design for the smart grid: combining the SGAM and NISTIR 7628. (2014). <https://doi.org/10.1109/COMPSCACW.2014.23>
26. SG-CG/M490/: Smart Grid Information Security. Standard, CEN, CENELEC, ETSI (2014)
27. Industrial Internet Consortium: The Industrial Internet of Things Volume G1: Reference Architecture (2019). <https://www.iiconsortium.org/pdf/IIRA-v1.9.pdf>
28. The Open Group: Reference Architectures and Open Group Standards for the Internet of Things—Four Internet of Things Reference Architectures (2021)
29. Industrial Internet Consortium: The Industrial Internet of Things Volume G4: Security Framework. IIC:PUB:G4:V1.0:PB:20160919 (2016). https://www.iiconsortium.org/pdf/IIC_PUB_G4_V1.00_PB.pdf
30. Ross, J.: Enterprise architecture: driving business benefits from it. *SSRN Electron. J.* (2006). <https://doi.org/10.2139/ssrn.920666>
31. ISO: ISO/IEC/IEEE Systems and software engineering—architecture description. ISO/IEC/IEEE 42010:2011(E) (Revision of ISO/IEC 42010:2007 and IEEE Std 1471-2000), 1–46 (2011). <https://doi.org/10.1109/IEEESTD.2011.6129467>
32. The Open Group: ArchiMate 3.1 Specification. The Open Group Series. Van Haren Publishing, Amersfoort (2019)
33. Pavleska, T.: In: Hudson, F.D. (ed.) Architecting and Evaluating Cybersecurity in Clinical IoT, pp. 21–47. Springer, Cham (2022)
34. Schweichhart, K.: Reference Architectural Model Industrie 4.0 (RAMI 4.0) (2015). https://ec.europa.eu/futurium/en/system/files/ged/a2-schweichhart-reference_architectural_model_industrie_4_0_rami_4.0.pdf
35. Grieves, M.: Digital twin: manufacturing excellence through virtual factory replication (2015)
36. Béceue, A., Fourastier, Y., Praça, I., Savarit, A., Baron, C., Gradusos, B., Pouille, E., Thomas, C.: Cyberfactory1—securing the industry 4.0 with cyber-ranges and digital twins. In: 2018 14th IEEE International Workshop on Factory Communication Systems (WFCS), pp. 1–4 (2018). <https://doi.org/10.1109/WFCS.2018.8402377>
37. Hanka, T., Niedermaier, M., Fischer, F., Kiefling, S., Knauer, P., Merli, D.: Impact of Active Scanning Tools for Device Discovery in Industrial Networks, pp. 557–572 (2021)
38. Pavleska, T., Aranha, H., Masi, M., Sellitto, G.P.: Drafting a cybersecurity framework profile for smart grids in EU: a goal-based methodology. In: Bernardi, S., Vittorini, V., Flammini, F., Nardone, R., Marrone, S., Adler, R., Schneider, D., Schleiß, P., Nostro, N., Olsen, R.L., Salle, A.D., Masci, P. (eds.) Dependable Computing—EDCC 2020 Workshops—A4RAILS, DREAMS, DSOGRI, SERENE 2020, Munich, Germany, September 7, 2020, Proceedings. Communications in Computer and Information Science, vol. 1279, pp. 143–155. Springer, Cham (2020). https://doi.org/10.1007/978-3-030-58462-7_12
39. Lim, K.Y.H., Zheng, P., Chen, C.-H.: A state-of-the-art survey of digital twin: techniques, engineering product lifecycle management and business innovation perspectives. *J. Intell. Manuf.* (2020). <https://doi.org/10.1007/s10845-019-01512-w>
40. Johnson, P., Lagerström, R., Ekstedt, M.: A meta language for threat modeling and attack simulations. In: Proceedings of the 13th International Conference on Availability, Reliability and Security. ARES 2018. Association for Computing Machinery, New York (2018). <https://doi.org/10.1145/3230833.3232799>
41. IEC: IEC 62443-2-1—Industrial communication networks—Network and system security—Part 2-1: Establishing an industrial automation and control system security program. Standard, International Electrotechnical Committee, Geneva (2010)
42. ETSI: TS 102 165-1 v5.2.3, CYBER; Methods and Protocols; Method and Pro Forma for Threat, Vulnerability, and Risk Analysis (TVRA) (2017)
43. MITRE: ATT&CK for ICS. https://collaborate.mitre.org/attackics/index.php/Main_Page (2022)
44. ETSI: TS 102 792 V1.2.1, Intelligent Transport Systems (ITS); Mitigation techniques to avoid interference between European CEN Dedicated Short Range Communication (CEN DSRC) equipment and Intelligent Transport Systems (ITS) operating in the 5 GHz frequency range (2015). https://www.etsi.org/deliver/etsi_ts/102700_102799/102792/01.02.01_60/ts_102792v010201p.pdf
45. OASIS: Advanced Message Queuing Protocol (AMQP) Version 1.0 (2012). <http://docs.oasis-open.org/amqp/core/v1.0/amqp-core-complete-v1.0.pdf>
46. ISO: ISO/IEC 20922:2016 Information technology—Message Queuing Telemetry Transport (MQTT) v3.1.1 (2016)
47. ETSI: EN 302 637-3, Intelligent Transport Systems (ITS); Vehicular Communications; Basic Set of Applications; Part 3: Specifications of Decentralized Environmental Notification Basic Service (2014)
48. Mao, X., Ekstedt, M., Ling, E., Ringdahl, E., Lagerström, R.: Conceptual abstraction of attack graphs—a use case of securicad. In:

- Albanese, M., Horne, R., Probst, C.W. (eds.) Graphical Models for Security—6th International Workshop, GraMSec@CSF 2019, Hoboken, June 24, 2019, Revised Papers. Lecture Notes in Computer Science, vol. 11720, pp. 186–202. Springer, Cham (2019). https://doi.org/10.1007/978-3-030-36537-0_9
49. The European Parliament and the Council of European Union: Directive (EU) 2004/54/EC on minimum safety requirements for tunnels in the trans-European road network (2004). <https://eur-lex.europa.eu/legal-content/EN/TXT/PDF/?uri=CELEX:02004L0054-20090807&from=PL>
 50. Bergmeister, K., Francesconi, S.: Causes and frequency of incidents in tunnels. Deliverable of the UPTUN project (2004)
 51. Ådne, N., Kvaløy, J.T., Njå, O.: Modelling fire occurrences in heavy goods vehicles in road tunnels. *Fire Saf. J.* **127**, 103508 (2022). <https://doi.org/10.1016/j.firesaf.2021.103508>
 52. PIARC—Technical committee 5 road tunnels: fire and smoke control in road tunnels. Technical Report, PIARC (1999). <https://www.piarc.org/ressources/publications/1/3860,05-05-B.pdf>
 53. Borghetti, F., Cerean, P., Derudi, M., Frassoldati, A.: Road Tunnels: An Analytical Model for Risk Analysis. SpringerBriefs in Applied Sciences and Technology, Springer, Cham (2019)
 54. Aranha, H., Masi, M., Pavleska, T., Sellitto, G.P.: Securing the metrological chain in IoT environments: an architectural framework. In: IEEE International Workshop on Metrology for Industry 4.0 & IoT, MetroInd4.0 & IoT 2021, Rome, Italy, June 7–9, 2021, pp. 704–709. IEEE, New York (2021). <https://doi.org/10.1109/MetroInd4.0IoT51437.2021.9488526>
 55. Dix, A.: A comparative analysis of the Mont-Blanc, Tauern and Gotthard tunnel fires. PIARC (2004)
 56. Andersen, C.A., Joergensen, K.C., Laritzen, E.K.: Cost-effectiveness of Protection Measures to Mitigate Terrorist Attacks on Bridges and Tunnels, vol. 134, pp. 341–351. WIT Press (2003)
 57. Anderson, K.: A risk-based approach to supporting the operator role in complex monitoring systems. In: Proceedings of the Twelfth Australian Workshop on Safety Critical Systems and Software and Safety-Related Programmable Systems—Volume 86. SCS'07, pp. 3–11. Australian Computer Society, Inc., AUS (2007)

Publisher's Note Springer Nature remains neutral with regard to jurisdictional claims in published maps and institutional affiliations.

Springer Nature or its licensor (e.g. a society or other partner) holds exclusive rights to this article under a publishing agreement with the author(s) or other rightsholder(s); author self-archiving of the accepted manuscript version of this article is solely governed by the terms of such publishing agreement and applicable law.



Massimiliano Masi received his M.Sc. in Computer Science and his Ph.D. from the University of Florence in the field of Formal Methods. He is working in Cybersecurity for Critical Infrastructures since 2007. Dr. Masi participated in large EU research projects involving 30+ organizations (public & private), and in the development of Cybersecurity specifications now in operation in such critical infrastructures as Healthcare and Road Transportation. He is working for Autostrade per

L'Italia, a motorway operator, as responsible for OT Cybersecurity Architectures.



Giovanni Paolo Sellitto is an ICT Engineer, graduated from La Sapienza University in Rome. He is currently employed in an Italian independent supervisory body and over the last ten years he has been involved in several large-scale, cross-border EU e-government projects. The focus of his research is on enterprise architecture, interoperability, data governance and digitalization in public sector.



Helder Aranha is a Naval Academy graduate, having pursued graduate studies in Telecommunications Engineering at Instituto Superior Técnico in Lisbon. Employed in the IT industry since 2012, he was involved in large-scale, cross-border EU pilots concerning the Digital Single Market, both as technical lead of a Portuguese pilot on public procurement and deputy lead of architecture group. His forays into research focus on enterprise architecture approaches to interoperability, cybersecurity and



Tanja Pavleska is a senior researcher at the Laboratory for Open Systems and Network, Jozef Stefan Institute. She graduated at the Faculty for electrical engineering in Skopje, Macedonia, at the Institute for Automation and System Engineering and obtained her Ph.D. from the Jozef Stefan International Postgraduate School. Her main interests and expertise are in systemic research and practice, information and data governance, in particular related to trust management and cybersecurity. She has been involved in many EU projects, especially such dealing with digitalization and interoperability of cross-border public services. She is currently leading the work on eGovernance in the Digital Europe for All project.